



PLAN DE CONTINUIDAD DEL NEGOCIO

Servicio de Monitoreo y Respuesta Gestionada MDR 24/7

Clave del servicio: SEC-2026-001

Fecha de elaboración: 14 de junio de 2026

Elaborado por: Equipo AmbarShield

Introducción

El presente Plan de Continuidad tiene como propósito garantizar la operación del Servicio de Monitoreo y Respuesta Gestionada MDR 24/7 (AmbarShield, clave SEC-2026-001) ante eventos que puedan afectar la disponibilidad, integridad o confidencialidad de los componentes tecnológicos y operativos que soportan el servicio.

El plan se fundamenta en los riesgos identificados durante el análisis del servicio, los niveles de servicio establecidos en el SLA y el OLA de la Cédula de Servicio, el inventario de activos descrito en el Anexo A y la criticidad de los procesos involucrados. Su finalidad es asegurar la continuidad del monitoreo de amenazas, la atención de incidentes y la protección de los activos tecnológicos de los clientes, minimizando el impacto operativo y reduciendo los tiempos de recuperación.

Objetivo del Plan de Continuidad

Garantizar la continuidad operativa del servicio MDR 24/7 mediante la implementación de procedimientos de respuesta y recuperación que permitan mantener el monitoreo de seguridad, la detección de amenazas y la atención de incidentes aun cuando se presenten fallas tecnológicas, eventos de seguridad o indisponibilidad de recursos críticos.

Alcance del Plan

Este plan aplica a los procesos críticos relacionados con:

- Monitoreo continuo de alertas EDR.
- Correlación y análisis de eventos de seguridad.
- Triage y clasificación de incidentes.
- Contención inicial de amenazas.
- Escalamiento de incidentes críticos.
- Gestión de reportes y métricas.



- Administración de la plataforma MDR y consola EDR.
- Conservación de telemetría y evidencias forenses.
- Gestión y resguardo de respaldos de información (estrategia 3-2-1).
- Disponibilidad y resguardo de playbooks de respuesta y documentación crítica.
- Auditoría e integridad de las bases de datos de alertas.

El plan cubre incidentes relacionados con infraestructura tecnológica, conectividad, servicios cloud, seguridad de la información, personal clave y proveedores externos.

De forma consistente con el alcance contractual definido en la Cédula de Servicio, este Plan de Continuidad no contempla la recuperación de respaldos del cliente ni la remediación forense avanzada; ambas actividades quedan fuera del alcance del servicio MDR 24/7 y, por lo tanto, fuera del alcance de este documento.

Procesos Críticos Identificados

Proceso	Nivel de criticidad
Monitoreo de alertas EDR	Crítico
Gestión y correlación de eventos	Crítico
Respuesta y contención de incidentes	Crítico
Escalamiento de incidentes de alta severidad	Alto
Gestión de telemetría y registros	Alto
Administración de la consola MDR/EDR	Alto
Generación de reportes y KPIs	Medio
Gestión de respaldos y recuperación de información	Crítico
Resguardo y disponibilidad de playbooks de respuesta	Alto
Auditoría de accesos a bases de datos de alertas	Medio

Estos procesos son esenciales para mantener la operación continua del servicio y cumplir con los acuerdos de nivel de servicio establecidos.

Escenarios de Interrupción

Escenario 1: Falla de la plataforma MDR o consola EDR

Impacto: Pérdida temporal de visibilidad sobre eventos de seguridad y retraso en la detección de amenazas.

**Procesos afectados:**

- Monitoreo de alertas.
- Correlación de eventos.
- Generación de reportes.

Activos involucrados:

- Consola EDR.
- Plataforma MDR.
- Dashboard de monitoreo.
- Base de datos de eventos.
- Consola SIEM (correlación centralizada de eventos).

Este escenario incluye el riesgo de un ataque de denegación de servicio (DDoS) distribuido sobre la Consola SIEM, identificado con riesgo Alto (ACT-01) en la Matriz de Riesgos. Control recomendado: clúster en espejo (alta disponibilidad) y protección perimetral DDoS.

Escenario 2: Interrupción de conectividad o servicios cloud

Impacto: Pérdida de comunicación entre endpoints y la plataforma central.

Procesos afectados:

- Recolección de telemetría.
- Monitoreo en tiempo real.
- Respuesta remota.

Activos involucrados:

- VPN.
- Red corporativa.
- Infraestructura cloud.
- Almacenamiento de logs.

Escenario 3: Ciberataque o compromiso de la plataforma

Impacto: Posible alteración de registros, interrupción del servicio o fuga de información.

Procesos afectados:

- Gestión de incidentes.
- Monitoreo.
- Conservación de evidencias.

Activos involucrados:



- Consola MDR.
- Bases de datos.
- Sistemas de autenticación.
- Threat Intelligence Feeds.
- Evidencia forense digital.

Para preservar la validez legal de la evidencia (riesgo Alto, ACT-05), el equipo de respuesta debe calcular de forma automática las firmas hash (SHA-256) de los artefactos recolectados y mantener la cadena de custodia desde el momento de la recolección.

Escenario 4: Indisponibilidad de personal clave

Impacto: Retraso en la investigación y respuesta a incidentes.

Procesos afectados:

- Triage.
- Escalamiento.
- Atención de incidentes críticos.

Activos involucrados:

- Coordinador MDR.
- Analista SOC N1.
- Analista SOC N2.

Escenario 5: Pérdida o corrupción de datos de telemetría y configuración

Impacto: Imposibilidad de consultar el histórico de eventos, reconstruir la línea de tiempo de un incidente o restaurar las políticas de detección vigentes, afectando la evidencia forense y los reportes de KPIs.

Procesos afectados:

- Gestión de telemetría y registros.
- Conservación de evidencias forenses.
- Generación de reportes y métricas.

Activos involucrados:

- Base de datos de eventos.
- Servidor de almacenamiento de logs.
- Configuraciones y políticas EDR.



Escenario 6: Cifrado simultáneo de respaldos por propagación de ransomware

Impacto: Pérdida total de la capacidad de restauración si tanto los servidores operativos como sus respaldos quedan cifrados por el movimiento lateral de un ransomware, dejando a la organización sin un punto de recuperación válido.

Procesos afectados:

- Restauración de la plataforma y sus configuraciones.
- Conservación de telemetría y evidencias forenses.
- Continuidad operativa general del servicio.

Activos involucrados:

- Respaldo de información (backups).
- Base de datos de eventos.
- Configuraciones y políticas EDR.

Activo de mayor riesgo en la Matriz de Riesgos (ACT-07, riesgo 14, Grado de criticidad V). Control recomendado: estrategia de respaldos 3-2-1, con al menos una copia desconectada (offline) de la red.

Escenario 7: Inaccesibilidad de los playbooks de contención durante un incidente

Impacto: Imposibilidad de ejecutar los procedimientos de respuesta estandarizados en el momento más crítico de la crisis, al estar los playbooks almacenados únicamente en servidores de archivos de la red corporativa, los cuales pueden quedar cifrados por un ataque de ransomware generalizado.

Procesos afectados:

- Contención inicial de amenazas.
- Escalamiento de incidentes críticos.
- Procedimiento de Activación y Escalamiento (sección 11).

Activos involucrados:

- Playbooks de respuesta y contención.
- Repositorio documental de procedimientos.

Riesgo Alto identificado en la Matriz de Riesgos (ACT-06, riesgo 11). Control recomendado: mantener copias de los playbooks en un repositorio cloud aislado de la red corporativa y en formato impreso.



Escenario 8: Uso indebido de privilegios sobre la base de datos de alertas

Impacto: Un usuario interno con privilegios elevados altera o elimina el estatus de alertas críticas para encubrir incidentes reales, retrasando su detección y atención.

Procesos afectados:

- Triage inicial de eventos.
- Investigación de incidentes.
- Generación de reportes y KPIs.

Activos involucrados:

- Base de datos de alertas.
- Consola SIEM.

Riesgo Medio identificado en la Matriz de Riesgos (ACT-03, riesgo 10), originado por la ausencia de registros de auditoría interna sobre modificaciones a la base de datos. Control recomendado: bitácoras de auditoría no modificables (append-only) y cifrado en reposo.

Estrategias de Continuidad y Recuperación

Escenario	Estrategia de continuidad
Falla de plataforma MDR/EDR	Activación de instancia de respaldo en la nube y restauración de configuración previamente respaldada.
Interrupción de conectividad	Uso de enlaces redundantes y restablecimiento de VPN segura.
Ciberataque a la plataforma	Aislamiento inmediato, activación del plan de respuesta a incidentes y recuperación desde respaldos seguros.
Pérdida o corrupción de datos	Restauración de telemetría y configuraciones desde repositorios protegidos.
Ausencia de personal clave	Redistribución temporal de funciones y escalamiento al SOC externo.
Cifrado simultáneo de respaldos (ransomware)	Implementar estrategia de respaldos 3-2-1 con al menos una copia desconectada (offline) de la infraestructura operativa.
Inaccesibilidad de playbooks	Mantener copias de los playbooks de contención en un repositorio cloud aislado de la red corporativa y en formato impreso.
Uso indebido de privilegios (amenaza interna)	Implementar bitácoras de auditoría de base de datos no modificables (append-only) y cifrado en reposo de la base de datos de alertas.



Tiempos de Recuperación (RTO / RPO)

Proceso / Activo	RTO	RPO
Monitoreo de alertas EDR	30 minutos	15 minutos
Consola MDR/EDR	1 hora	30 minutos
Gestión de incidentes críticos	15 minutos	0 minutos
Base de datos de eventos	2 horas	1 hora
Dashboard y reportes	4 horas	2 horas
Conectividad (VPN / Red corporativa)	1 hora	15 minutos
Configuraciones y políticas EDR	2 horas	24 horas
Threat Intelligence Feeds	1 hora	Continua (tiempo real)
Respaldo de información (backups)	4 horas	24 horas (copia offline)
Playbooks de contención	30 minutos	N/A (documento controlado por versiones)
Base de datos de alertas / Consola SIEM	1 hora	15 minutos

Las dos últimas filas se incorporan para cubrir los activos asociados a los Escenarios 2, 3 y 5 (conectividad, configuraciones EDR e inteligencia de amenazas), que no contaban con tiempos de recuperación definidos en la versión previa del plan.

Adición v1.2: se incorporan los activos Respaldo de información, Playbooks de contención y Base de datos de alertas / Consola SIEM, derivados de los activos ACT-07, ACT-06 y ACT-03 de la Matriz de Riesgos.

Nota sobre el RPO y el almacenamiento de telemetría: conforme al BIA Operacional, el almacenamiento de telemetría e inteligencia en la nube se contrata de forma mensual, pero el respaldo de eventos forenses se mantiene en tiempo real. Por lo tanto, los RPO de esta tabla representan el punto de recuperación operativo del servicio y no el ciclo de facturación del almacenamiento contratado.

Roles y Responsabilidades

Rol	Responsabilidad
Coordinador MDR	Activar el Plan de Continuidad y coordinar la recuperación.
Analista SOC Nivel 1	Monitoreo y validación inicial de incidentes.
Analista SOC Nivel 2	Investigación y recuperación operativa.
Área de TI del cliente	Apoyo en acciones de contención local.
Proveedor SOC externo	Soporte especializado y escalamiento 24/7.



Información basada en la estructura operativa definida para el servicio.

Directorio de contactos para activación del plan

El siguiente directorio corresponde al personal asignado en la Cédula de Servicio y debe utilizarse como referencia inmediata durante la activación y el escalamiento del plan.

Rol	Nombre	Correo electrónico	Teléfono	Horario
Coordinador MDR	Bueno Pérez Edith	edithperez@gmail.com	5566778888	09:00–18:00
Analista SOC Nivel 1	Ávila Cigarroa Aarón Axel	avila3aaron@gmail.com	5522345521	09:00–18:00
Analista SOC Nivel 2	Juan Albert Arias	Albert231ja@gmail.com	5554256921	09:00–18:00
Cliente / Área TI	Asociación SA de CV	aso@aso.org	5554256920	N/A

Nota: cobertura 24/7: el horario formal del personal indicado es de 09:00 a 18:00, mientras que el OLA exige operación continua 24/7 y respuesta a alertas críticas en menos de 15 minutos. Se recomienda definir un esquema de guardias rotativas (on-call) o el respaldo permanente del Proveedor SOC externo fuera de este horario, conforme al Escenario 4 (Indisponibilidad de personal clave).

Vinculación con los Niveles de Servicio (SLA y OLA)

La siguiente tabla relaciona los compromisos contractuales definidos en la Cédula de Servicio (secciones 5 y 6) con las estrategias y tiempos de recuperación establecidos en este Plan de Continuidad, evidenciando que el plan responde directamente a los acuerdos de nivel de servicio vigentes.

Compromiso establecido (SLA/OLA)	Meta / valor	Relación con el Plan de Continuidad
Disponibilidad mensual de la consola y reporte de agentes	99.9%	Sustenta los RTO de la Consola MDR/EDR (1 hora) y de la Base de datos de eventos (2 horas); las ventanas de mantenimiento programadas no se contabilizan como caídas.
Tiempo de respuesta a alertas críticas (SOC 24/7)	Menor a 15 minutos	Define el RTO de Gestión de incidentes críticos (30 minutos) y el RPO de 0 minutos para dicho proceso.
Capacidad de la plataforma	100 nodos sin degradación	Garantiza que la instancia de respaldo del Escenario 1 mantenga la misma capacidad operativa del servicio.
Seguridad de la plataforma (MFA, cifrado, NIST CSF / ISO 27001)	Crítico	Sustenta la estrategia de aislamiento y recuperación segura frente al Escenario 3 (ciberataque).



Respaldo periódico de telemetría y configuraciones EDR	Periódico (almacenamiento cloud)	Sustenta la estrategia y los tiempos de recuperación del Escenario 5 (pérdida o corrupción de datos).
Reducción de falsos positivos	Mayor al 80%	Reduce el riesgo de fatiga de alertas y saturación del equipo SOC durante una contingencia, facilitando el cumplimiento de los RTO definidos.
Auditoría e integridad de bases de datos críticas (ACT-03)	Bitácoras append-only + cifrado en reposo	Sustenta la estrategia del Escenario 8 (uso indebido de privilegios sobre la base de datos de alertas).

Procedimiento de Activación y Escalamiento

Criterios de activación

El Plan de Continuidad se activa cuando se presenta alguna de las siguientes condiciones:

- Indisponibilidad de la Consola MDR/EDR por más de 15 minutos.
- Pérdida de conectividad entre los endpoints y la plataforma central.
- Confirmación de un incidente de ciberseguridad que afecte la plataforma, las bases de datos o los sistemas de autenticación.
- Pérdida o corrupción confirmada de telemetría, configuraciones o registros de eventos.
- Ausencia no programada de personal clave que comprometa el cumplimiento del SLA.
- Cifrado o indisponibilidad simultánea de los respaldos de información (Escenario 6).
- Pérdida de acceso a los playbooks de contención durante un incidente activo (Escenario 7).

Cadena de notificación y escalamiento

1. El Analista SOC Nivel 1 detecta el evento (o recibe el reporte) y realiza la validación inicial.
2. El Analista SOC Nivel 1 notifica de inmediato al Coordinador MDR mediante el canal definido (correo electrónico, sistema de tickets o teléfono).
3. El Coordinador MDR evalúa el evento contra los criterios de activación (sección 11.1) y, de confirmarse, declara la activación del Plan de Continuidad.
4. El Coordinador MDR notifica al Cliente / Área TI y, de ser necesario, escala al Analista SOC Nivel 2 y al Proveedor SOC externo para iniciar las acciones de recuperación correspondientes (sección 7).
5. Una vez restablecido el servicio dentro de los tiempos definidos en la sección 8, el Coordinador MDR documenta el evento y notifica el cierre a todas las partes involucradas.

El personal de respuesta debe contar con acceso garantizado a la copia aislada/impresa de los playbooks (Escenario 7) durante la ejecución de esta cadena de notificación, incluso si la red corporativa no está disponible.



Pruebas y Actualización del Plan

- El Plan de Continuidad deberá probarse al menos una vez por año mediante:
- Simulación de caída de la consola MDR.
- Simulación de pérdida de conectividad.
- Simulación de incidente de ransomware.
- Simulación de indisponibilidad del personal clave.
- Simulación de pérdida o corrupción de telemetría y configuraciones.
- Simulación de cifrado simultáneo de servidores operativos y respaldos (Escenario 6), validando la restauración desde la copia offline.
- Simulación de pérdida de acceso a los playbooks de contención (Escenario 7), validando el uso de las copias aisladas/impresas.

La primera validación del marco de respuesta puede apoyarse en los ejercicios de Red Teaming programados durante la Fase 4 del proyecto (semanas 14 a 17). Los resultados de dichas simulaciones de ataque controlado servirán como línea base para ajustar los procedimientos de contención y los tiempos de recuperación establecidos en la sección 8.

Los resultados de cada prueba deberán documentarse y utilizarse para actualizar procedimientos, tiempos de recuperación y responsabilidades.

Asimismo, cualquier cambio en la infraestructura, los acuerdos de servicio, los riesgos identificados o los componentes tecnológicos deberá reflejarse en una actualización formal del plan.

Adicionalmente, los hallazgos de cada prueba o incidente real deberán registrarse en la Bitácora de Lecciones Aprendidas (Anexo A), con responsable y fecha límite asignados; su cumplimiento se evaluará mediante KPIs mensuales como parte del plan de mejora continua, conforme al control identificado para el activo ACT-09.



Control de Versiones

Versión	Fecha	Descripción del cambio	Elaborado por
1.0	12/06/2026	Versión inicial del Plan de Continuidad.	Equipo AmbarShield
1.1	14/06/2026	Incorporación del Escenario 5 (pérdida o corrupción de datos) y su estrategia y tiempos de recuperación; vinculación con SLA/OLA; directorio de contactos; procedimiento de activación y escalamiento; Anexos A y B.	Equipo AmbarShield
1.2	15/06/2026	Revisión cruzada con el Análisis de Riesgos y los BIA Táctico/Operacional: ajuste del RTO de Gestión de incidentes críticos a 15 minutos; nuevos Escenarios 6-8 (respaldos cifrados, inaccesibilidad de playbooks, uso indebido de privilegios) y sus estrategias y RTO/RPO; nuevos procesos críticos y activos en Anexo A (Consola SIEM, Evidencia forense digital, Playbooks, Respaldos, Reporte final, Bitácora de lecciones aprendidas); nuevos términos en Anexo B; Anexo C de referencia al BIA Táctico del proyecto.	Equipo AmbarShield



Anexo A. Inventario de Componentes de Infraestructura

Inventario de los activos tecnológicos referidos en los escenarios de interrupción (sección 6), conforme a la Cédula de Servicio.

Componente	Tipo	Función
Endpoints protegidos (PCs y servidores)	Hardware	Equipos donde se instalan los agentes EDR para recopilar telemetría y detectar amenazas.
Agentes EDR	Software	Monitorean procesos, archivos, conexiones y eventos de seguridad en cada endpoint.
Consola EDR Central	Aplicación	Administra agentes, recibe alertas, ejecuta acciones de contención y genera reportes.
Plataforma MDR / SOC	Servicio	Realiza correlación de eventos, análisis, triage y respuesta ante incidentes.
Servidor de almacenamiento de logs	Infraestructura Cloud	Almacena telemetría, eventos y evidencia para análisis forense.
Base de datos de eventos	Software	Conserva registros históricos de alertas e incidentes.
Threat Intelligence Feeds	Servicio externo	Proporciona indicadores de compromiso (IoC) y firmas actualizadas de amenazas.
Red corporativa	Infraestructura de red	Permite la comunicación entre endpoints, consola EDR y plataforma MDR.
VPN o canal seguro	Seguridad	Protege las comunicaciones entre el cliente y el SOC.
Consola de reportes y dashboards	Aplicación	Presenta KPIs como MTTD, MTTR, incidentes y tendencias.
Correo electrónico y sistema de tickets	Servicio	Permite notificaciones y escalamiento de incidentes.
Consola SIEM	Aplicación	Correlaciona y analiza eventos de seguridad de múltiples fuentes; requiere MFA estricto para accesos administrativos (control ACT-01).
Evidencia forense digital	Información	Artefactos recolectados durante la investigación de incidentes; se resguarda con hash SHA-256 y cadena de custodia (control ACT-05).



Playbook de contención	Documento	Procedimientos estandarizados de respuesta; se mantiene en repositorio cloud aislado y copia impresa (control ACT-06).
Respaldo de información (backups)	Infraestructura Cloud / Offline	Copias de seguridad de servidores operativos bajo estrategia 3-2-1 con copia desconectada (control ACT-07).
Reporte final del incidente	Documento	Informe de cierre del incidente; cifrado y de acceso restringido al Comité de Crisis (control ACT-08).
Bitácora de lecciones aprendidas	Documento	Registro de hallazgos y acciones de mejora, vinculado al plan de mejora continua y evaluado mediante KPIs mensuales (control ACT-09).



Anexo B. Glosario de Términos

- **Dwell Time:** Tiempo de permanencia de un atacante dentro de la red antes de ser detectado y contenido.
- **EDR (Endpoint Detection and Response):** Solución de ciberseguridad enfocada en detectar, investigar y responder a amenazas en equipos finales como computadoras, laptops y servidores.
- **Falso positivo:** Alerta generada por una herramienta de seguridad que, tras revisarse, no corresponde a un incidente real.
- **MBCO (Minimum Business Continuity Objective):** Nivel mínimo de servicio aceptable durante una interrupción, que permite mantener los objetivos esenciales del negocio mientras se restablece la operación completa (parámetro definido en el BIA Táctico).
- **MDR (Managed Detection and Response):** Servicio administrado de monitoreo, detección y respuesta ante amenazas, operado por especialistas externos o por un proveedor de seguridad.
- **MTPoD / MAO (Maximum Tolerable Period of Disruption / Maximum Acceptable Outage):** Tiempo máximo que puede transcurrir antes de que los impactos de una interrupción se vuelvan inaceptables para la organización (parámetro definido en el BIA Táctico).
- **OLA (Operational Level Agreement):** Acuerdo de nivel operativo que define los compromisos internos sobre los elementos de configuración (infraestructura, aplicaciones y servicios) que soportan el servicio.
- **Playbook:** Manual de procedimientos estandarizados que indica paso a paso las acciones a seguir ante un tipo específico de incidente.
- **RPO (Recovery Point Objective):** Antigüedad máxima aceptable de la información que puede perderse durante una interrupción, medida hasta el punto de recuperación más reciente.
- **RTO (Recovery Time Objective):** Tiempo máximo aceptable para restablecer un proceso o componente después de una interrupción.
- **SLA (Service Level Agreement):** Acuerdo de nivel de servicio que establece los compromisos del proveedor frente al cliente o usuario final.
- **SOC (Security Operations Center):** Centro de operaciones de seguridad encargado de monitorear eventos, analizar alertas y coordinar la respuesta ante incidentes.
- **Telemetría:** Conjunto de datos detallados sobre la actividad de un endpoint (procesos, archivos, conexiones) que permite el análisis y la reconstrucción de eventos.



Anexo C. Continuidad de las Fases del Proyecto (Referencia BIA Táctico)

Este anexo se incorpora en la v1.2 como referencia complementaria. Mientras que las secciones 1 a 13 cubren la continuidad del servicio MDR 24/7 ya operativo, el BIA Táctico evalúa la continuidad de las fases de implementación del proyecto SEC-2026-001. Si se requiere, este anexo puede desarrollarse como una sección completa con sus propios escenarios y estrategias de continuidad para el periodo de despliegue.

Proceso (fase del proyecto)	MTPoD	RTO	Responsable	MBCO (resumen)
Diagnóstico y Diseño de Arquitectura	< 12 hr	< 5 hr	Velasco Jiménez Luis (Ciberseguridad / Consultoría Lógica)	El Cybersecurity Architect continúa la auditoría y el modelado de red de forma local, preservando comunicación telefónica con el cliente.
Despliegue y Configuración Técnica	< 2 hr	< 1 hr	Huerta Vásquez Mariel (Operaciones e Infraestructura SOC)	Los agentes EDR operan de forma autónoma; el instalador se distribuye manualmente vía almacenamiento externo sin conexión a internet.
Gestión de Respuesta y Optimización	< 1 hr	< 15 min	Pérez Hernández Edgar (Operaciones e Inteligencia de Amenazas / Respuesta a Incidentes)	Aislamiento manual con playbooks impresos y canal alterno de alertas (teléfono o mensajería cifrada) con el SOC externo.